

## [대외비] (주)하랑케이터링 수탁자 현황 자료

### 1. 수탁자 기본 현황

- 회사명: (주)하랑케이터링 (Harang Catering)
- 대표자: 최호진
- 설립일: 2010년 3월 1일
- 소재지: 인천광역시 중구 공항동로
- 직원 수: 총 300명 (경영지원 50명, 기내식 생산/주방 현장직 200명, 배송·물류 50명)
- 주요 사업: 항공기 기내식 제조 및 탑재, 특수식(알레르기·종교·VIP) 분류·포장·배송
- ISMS-P 인증 미보유
- 개인정보보호책임자(CPO): 미기재 (임원급 지정, 반기 경영진 보고 수행)

### 2. 개인정보 위탁 업무 내역

- 위탁자: (주)하랑항공
- 위탁 업무: 하랑항공 승객 대상 기내식 및 특수식 서비스
  - 기내식 제조 및 탑재 조업
  - 특수식(알레르기·종교식·병리식·영유아식 등) 분류 및 좌석별 배송
  - 노선·좌석등급 기준 식수 산정 및 통계 관리
  - 출발 24시간 전 SFTP/TLS 암호화 전송 방식으로 하랑항공 시스템에서 데이터 수신
  - 자체 CMS/ERP(Oracle EBS) 업로드 후 생산·배송 단말기에서 조회 처리
- 계약 기간: 2025년 3월 1일 ~ 2026년 3월 1일 (1년, 연간 자동 갱신 조항 포함)
- 개인정보 재위탁 현황
  - 재위탁 시 원위탁자(하랑항공) 사전 승인 절차 운영 중 확인
  - 식재료 공급업체에 카카오톡으로 승객 정보를 전달하는 사례 확인

### 3. 처리하는 개인정보 항목 및 규모

- 데이터 접근 방식
  - 수집: 하랑항공 시스템에서 출발 24시간 전 SFTP/TLS 암호화 전송 방식으로 데이터를 수신함
  - 이용: 수신 데이터를 자체 CMS/ERP(Oracle EBS)에 업로드 후 생산·배송 단말기에서 조회. 특수식 정보는 별도 권한 사용자만 조회 가능
- 처리 개인정보 항목
  - 승객명, 연락처, 예약번호, 항공편명, 출발/도착 일정
  - 좌석 등급, 마일리지 등급
  - 민감정보: 알레르기, 질환, 종교 등 식이 제한 정보
- 처리 규모
  - 일평균 약 10,000명 승객 데이터 처리
- ※ 특수식 정보는 민감정보에 해당하므로 취급자 최소화 및 별도 접근 통제 필요

### 4. 개인정보 처리 시스템 현황(논리적 망분리 환경)

- 시스템 구성
  - ERP/CMS 서버: Oracle EBS R12.2 기반 기내식 생산·주문 관리 (On-premise, 총 4대 운영)
  - 운영 DB: 승객 예약번호, 연락처, 특수식(알레르기·종교·병리) 등 민감정보 저장 (Oracle DB, AES-256 암호화 적용)
  - SFTP 서버: 하랑항공 승객 명단 수신 전용 (On-premise, DMZ 구간 배치, 일 평균 10,000건 수신)
  - 현장 단말: 생산지시 및 배송 관리용 PDA(약 30대) 및 현업 공용 단말기(약 15대) 운영
  - 백업 시스템: Oracle EBS 위기대응 매뉴얼 기반 정기 백업 및 하랑항공 승객명단 별도 백업 저장소 운영
- 네트워크(논리적 망분리)
  - DMZ 구간에 SFTP 서버 배치, 내부 운영 DB와 별도 방화벽으로 구분
  - 업무망 접근은 Cisco ASA 5516-X VPN + OTP(TOTP) 이중 인증 후 허용
  - 하랑항공 연동 구간은 SFTP + TLS 1.2 이상 암호화 전용 채널 사용
  - URL 필터링·비인가 프로그램 차단 정책 적용 중이나, SSL Inspection 미적용으로 HTTPS 경유 개인 클라우드 접속·파일 업로드 탐지·차단 불가. 이메일 DLP만 적용, 웹·엔드포인트 DLP 미도입
  - 현장 휴게 공간 등 일부 구간 무선 LAN(Wi-Fi) 사용 기준 및 비인가 AP 점검 체계 부재

## 5. (자체 점검) 보안 관리 현황

### 5.1 내부 관리 계획 및 조직

- CPO(경영지원팀장 이수진 이사) 임원급 지정, 전자결재 인사발령 및 임명장 보유. 반기마다 경영진 보고 수행 확인
- 내부관리계획서 수립·대표이사 최호진 결재 후 전사 공고 확인. 침해사고 신고 기한(현행 72시간) 미반영, 재위탁 수탁자 관리감독 실행계획 누락
- 처리방침을 인트라넷·그룹웨어 상단 고정으로 사무직(50명) 대상 공표 확인.  
운영/주방/생산(200명)·배송/물류(50명) 등 PC 접근 제한 인력에 대한 오프라인 공표 수단(소책자·현장 게시판 등) 미존재
- 사무직·주방·배송 전원(300명) 입사 시 보안서약서 징구, 퇴사 시 비밀유지 서약 재징구, 연간 갱신 확인.  
Oracle EBS 유지보수 외부 인력 등 보호구역 출입 인력 사전 서약 통제 확인. 파트타임·단기 용역 직원 일부 서약 미징구
- CPO·정보보안 담당자(박민준 과장·김태희 주임)·취급자 77명 전원 대상 2025.07.10 정기 교육 수행 확인.  
CPO/담당자 외부교육 수료증 및 교육참석대장 구비 확인. 특수식 민감정보 처리 인력 대상 침해사고 대응 실무 교육 포함 확인
- 취급자 목록(2025.12 기준: 경영지원 12명·주방/생산 47명·배송/물류 18명, 총 77명) 운영. 2025년 하반기 신규 입사자 중 5명 미반영. 승객정보를 직접 취급하지 않는 단순 현장 관리 인력 포함

### 5.2 접근 통제 및 권한 관리

- 외부 접속 시 VPN(Cisco ASA 5516-X, AES-256) + MFA 적용. 하랑항공 SFTP/TLS 대외 연계 구간 암호화 통신 확인
- 기업용 무선랜(WPA3 + WIPS) 보안 적용 확인. 일부 현장 휴게 공간에서 문서화 없이 무선랜 사용 사례 존재. 비인가 AP 정기 점검 절차 미존재
- Oracle EBS 계정은 취급자 77명에게만 부여(Admin IT인프라팀 3명/일반사용자 구분), 외부 협력 계정에 'EXT\_' 접두사 적용 확인. 주방 생산/배송 현장 단말에서 공용계정 사용 확인
- 퇴사 후 7일 이내 계정 삭제 지침 존재. 2025년 퇴사자 중 계정 미삭제 7명 확인. 업무 변경 후 접근권한·엑셀 다운로드 권한 미회수 3명 확인. 인사부서-IT/보안부서 간 실시간 인사정보 공유 체계 미존재
- 주요 시스템 비밀번호 복잡도·90일 유효기간·최근 5회 재사용 금지 기준 적용 확인. 현장 PDA 단말 등 일부 계정 적용 증적 미존재. 공용단말·임시계정 예외 승인 체계 미존재
- ERP 세션 타임아웃 30분 설정 확인. 현장 주문관리 단말 일부 120분 이상 또는 미적용 사례 확인
- 방화벽·IDS/IPS 기본 체계 운영 확인. 예외 허용 룰 12건 존재, 정기 재검토 기록 미존재. 로그인 실패 5회 계정 잠금 정책 주요 시스템 적용 확인. 일부 현장 공용단말·레거시 계정 동일 기준 적용 증적 미존재
- 계정 신청·승인은 부서장 또는 CPO 전자결재 기반 운영 확인. 2025년 신규 계정 38건 중 6건 승인 문서와

실제 권한 불일치 확인. 야간·새벽 긴급 조업 시 구두 협의 후 사후 승인 관행 존재. 생산현장 단말 2대 계정 공유 사례 확인

- 사무직 단말 화면보호기·재로그인 설정 확인. 생산·배송 PDA 단말 일부 화면보호기 대기시간 30분 이상 또는 미적용 확인. 3교대 인수인계 시 단말 잠금 해제 상태 방치 가능성 존재
- Oracle EBS R12.2 정기 패치 수행 확인. 연계 미들웨어·OS 패치 지연 사례 확인. 취약점 점검 결과 11건 중 4건 미조치 상태, 재점검 기록 확인. 구버전 ERP 미패치로 인한 승객 3만 명 데이터 유출 이력 존재
- 계정권한관리대장(담당: 김태희 주임) 운영, 최근 2년 기록 확인. 2021년 이전 일부 기록 누락. 임시계정(Oracle EBS 유지보수 협력업체 5건) 사용 기간·사유 기록 불명확. 수기 대장과 인사시스템 간 일시적 불일치 사례 확인

### 5.3 접속기록 보관 및 점검

- Oracle Audit Vault 기반 ERP/CMS 접속기록(계정·접속일시·수행업무 등) 생성·저장 확인. 1년 이상 보관 확인. 일 평균 10,000명 특수식 민감정보 처리 특성상 2년 이상 보관 대상 해당 여부 판단 기준 미존재
- 로그 접근권한 제한(박민준 과장·김태희 주임), 저장영역 분리 등 기본 통제 적용 확인. Oracle Audit Vault 기본 무결성 기능 활용 확인. 불변 저장·해시값 생성·전자서명 등 강화 무결성 조치 부분 적용
- 2025년 로그 검토 이력: 4월·7월·10월 분기별 수행 확인. 대량 조회·특정 기간 집중 조회·야간 비정상 조회 등 이상행위 식별 기준 미문서화. 특수식 정보 대량 조회 등 케이터링 특성 반영한 탐지 항목 미존재
- 접속기록 백업 주기 표준화 미존재(현재 월 1회 수동 백업). 운영계와 분리된 백업 저장소 미존재. 최근 2년 내 복구 테스트 이력 미확인
- 공용단말 사용 구간·외부 연계 화면(SFTP 수신 구간 포함)·일부 배치 처리 영역에서 사용자 행위 단위 추적성 미존재. ERP 조회/변경 대상 정보 상세 로그 미기록. 로그 생성 누락 점검 및 결과 기록 절차 미문서화(담당 지정: 김태희 주임)
- 연 1회 취약점 점검 수행 확인. 점검 범위·결과보고서 보존 일관성 미존재. Oracle EBS 응용프로그램 중심 점검 확인. 서버·네트워크 장비·SFTP 수신 연계 구간 포함 전방위 점검 미존재. 외부 전문업체 모의해킹 미실시. SFTP 수신 포트 등 외부 노출 구간 별도 점검 기준 미존재

### 5.4 비밀번호 관리

- Oracle EBS 사용자 계정 비밀번호 SHA-256 기반 일방향 암호화 저장 확인. 레거시 현장 주문관리 모듈 및 연계 API 구간 동일 기준 적용 확인. 복잡도, 길이, 유효기간(90일), 재사용 제한(최근 5회) 기준 수립 및 적용 확인
- 기내식 생산 현장, 서버실(지하 1층), 특수식 처리구역 등 보호구역에 번호키/지문인식 출입통제 설치 및 방문객 출입 기록 관리대장 운영 확인. 인사이동 및 퇴직 시 출입권한 즉시 삭제 프로세스 정상 작동 확인
- 서버실 작업일지와 실제 출입 기록 간 불일치 3건 확인. 키관리대장 2025년 반납 미기재 7건 확인 및 대장 관리 체계 부재. 번호키를 현장 관리자 3명이 무단 공유하는 권한 통제 실패 사례 확인. 생산현장

단말 2대에서 책임자 승인 없는 계정 공유 확인

## 5.5 접속 보안 및 네트워크

- 하랑항공 승객 명단 수신 시 SFTP(TLS 1.2 이상) 암호화 통신 적용 및 7-Zip AES-256 파일 암호화 확인. 외부 연계 구간 VPN(Cisco ASA 5516-X) 기반 암호화 통신 및 사용자 인증 절차 운영 확인
- Oracle EBS R12.2 기반 CMS/ERP 내부망 중심 운영 및 인가된 서비스 중심 허용 정책(Whitelist) 기반 방화벽 운영 확인. SFTP 수신 서버(DMZ) 구간 논리적 분리 수준 차이 존재 및 현장 배송팀 단말 구간 통제 수준 낮은 외부망 연계 경로 확인
- SFTP 수신 이력 로그 관리 확인. 전송 오류 및 비정상 접속 알림 정기 검토 체계 미존재. 망분리 예외 구간에 대한 CPO 승인, 사용기간 관리, 정기 재검토 절차 미명확. 무선 LAN 사용 기준은 존재하나 단계별 승인 증적 부재 및 인가 AP 목록 미관리

## 5.6 단말기 보안

- Oracle EBS 운영 서버(4대) 및 관리 단말 백신(V3 Net) 설치 및 최신 엔진 업데이트 확인. 취급자 단말 77대 중 72대 백신 설치 확인 및 미설치 5대(현장 PDA 등) 확인. PC 50대 중 6대 최신 패치 미적용 확인. Windows 10(2025.10 EOS 예정) 사용 단말 현황 미파악 및 교체 계획 미수립
- 사무직 PC 대상 유해사이트 및 비인가 소프트웨어 차단 정책 적용 확인. 현장·배송 단말(PDA 등) 예외 운영 및 전수 점검 주기 증적 미흡. PDA 등 휴대 장비(약 30대) 시건·보관 기준 미설정
- 점검 시 현장 PC 12대 중 3대에서 공용폴더 발견 및 전사 일관 차단 정책 미적용. 데이터 공유 시 사용자별 계정 및 패스워드 설정 비밀관적 적용 확인. 생산팀 공용폴더 1개 운영에 따른 개인정보 노출 위험 존재 및 정기 점검 체계 부재

## 5.7 개인정보 암호화 및 출력 통제

- Oracle EBS DB 주요 컬럼 AES-256 암호화 저장 및 승객 성명·연락처 마스킹 적용 확인. 2025년 DB 점검 시 임시 테이블 2건 평문 데이터 잔존 확인 및 조치 완료 여부 확인 필요. SFTP 수신 서버(DMZ) 내 임시 저장 파일 암호화 기준 적용 여부 미확인
- Oracle EBS 암호화 키 관리대장 미운영 및 키 접근 인원(2명) 승인 절차·사용 목적 기록 부재. HSM 미적용 상태로 서버실 내 보관 중이며 키 교체 주기, 폐기 확인서 등 운영 절차 전무
- 생산지시서, 특수식 라벨(일 평균 150~200매) 잠금 캐비닛 보관 확인 및 문서 이동 시 박스 밀봉 조치 확인. 보안 Seal 부착 등 무결성 보장 조치 미적용. 특수식 라벨과 생산지시서 간 마스킹 노출 자리수 불일치 확인. 현장 출력물 미기록 15건 확인 및 특수식 주문서를 일반 쓰레기로 폐기하는 사례 현장 확인

## 5.8 개인정보 생명주기

- 법령 의무 보존기간 기준 확인 및 법정 보존 정보 접근권한 제한(CPO 등 2명) 확인. 의무 보존기간 종료 후 자동 알림 및 파기 승인 표준 절차 구축 확인. 다만 항공편 출발 후 5일 이내 즉시 파기 원칙 준수 여부 증적화 절차 미구축
- 단말기 내 일반 삭제 방식 사용으로 데이터 복구 가능성 존재. Eraser(파일 덮어쓰기) 도구 일부 사무직 단말에만 설치 및 현장 단말 전사 적용 미이행. DB 내 개인정보 물리 삭제 절차는 존재하나 백업본·이관본까지의 동시 반영 확인 절차 미명확
- 2025년 파기 결과 보고 8건에 그침. 1년 2개월간(2026.04~) 하랑항공에 파기 결과 보고 전무하며 자동 보고 연동 미존재 및 담당자 미지정(개인정보보호법 제26조 해당). DB, 다운로드 저장소, 출력물, SFTP 임시 저장 영역 전 위치 동시 파기 확인 절차 부재
- 침해사고 대응절차서 및 위탁자 보고 체계 수립 확인. Oracle EBS 위기대응 매뉴얼 및 정기 백업 계획 확인. 실제 복구 테스트 및 모의훈련 이력 전무하며 백업본 소산 정책 부재. RTO/RPO 기준 미설정으로 매뉴얼 실효성 미흡

## 6. 개인정보 재위탁 현황

- 재위탁 시 원위탁자(하랑항공) 사전 승인 절차 운영.
- 재위탁 계약서 내 필수 보안 조항(목적 외 처리 금지·관리감독·보호조치·재위탁 제한 등) 일부 누락  
재수탁사 정기 점검·감독 체계 부분 운영, 카카오톡으로 승객 정보 전달 사례 확인